Koleksi digital milik UPT Perpustakaan ITB untuk keperluan pendidikan dan penelitian

Chapter II Literature Review

II.1. Theoretical Foundation

In the context of regulatory changes by regulators, a strategy is needed in anticipating the impact of risks that will be faced by Ropari hospital. To address the challenges and gaps outlined in Chapter 1, this study adopts a multi-framework approach in terms of enterprise risk management, privacy governance, and legal compliance. In this chapter there are foundational frameworks that will shape the structure of the research design that will guide thematic analysis from which improvement recommendations will be derived.

One of the primary frameworks employed is the COSO Enterprise Risk Management (ERM) 2017 that support the evaluation of governance structures and risk handling in relation to privacy risk in hospital, ISO/IEC 27701:2019 Privacy Information Management System (PIMS) is used to detail privacy-specific control mechanisms that align with the requirements of Indonesia's Personal Data Protection (PDP) Law.

Specifically in this case of Ropari hospital, implementing key principles such as data minimization, access restriction and data encryption will strongly structure the framework to manage patient personal data responsibly and to make sure the actionable control and preventive measures for safeguarding personal data.

This integrative approach informs the design of the research instruments, the coding of qualitative data, and the development of targeted recommendations in subsequent chapters. By embedding privacy governance within the broader domains of risk management, operational control, and regulatory compliance, the study emphasizes the necessity for cross-functional accountability.

Importantly, this theoretical foundation reinforces that privacy is not merely an IT issue, but a strategic concern tied to institutional governance, compliance alignment, and the cultivation of patient trust. In doing so, the study positions privacy risk management as a core component of enterprise-wide strategic risk management.

Koleksi digital milik UPT Perpustakaan ITB untuk keperluan pendidikan dan penelitian

II.1.1. COSO ERM Framework

The COSO Enterprise Risk Management (COSO ERM) framework provides a structured approach to managing organizational risks, emphasizing governance, risk assessment and control activities into strategic objectives (COSO, 2017) with five components as shown in figure 2.1:

1. Governance & Culture: This component emphasizes the importance of establishing a strong governance structure and risk-aware culture. It includes principles related to board oversight, organizational ethics and values, risk appetite, and the risk management roles and responsibilities of various stakeholders within the organization.
2. Strategy & Objective Setting: This component focuses on integrating risk management into the organization's strategic planning and objective-setting processes. It involves principles such as evaluating risk in the formulation of strategy, setting business objectives considering the risk appetite, and developing risk tolerance thresholds for various objectives. (e.g., PDP Law Compliance)
3. Performance: The performance component involves the identification, assessment, prioritization, and response to risks. This includes principles such as risk identification, risk assessment, risk prioritization, risk response, and reporting on risk, culture, and performance. (e.g., potential data breaches in SIMRS).
4. Review & Revision: This component aims to ensure continuous improvement in risk management through regular review and revision of the risk management processes. The principles include reviewing risk and performance, pursuing improvements in risk management, and modifying risk management practices based on the lessons learned.
5. Information, Communication, & Reporting: The final component focuses on the effective flow of risk-related information throughout the organization. This includes principles such as leveraging information and technology to support risk management, communicating risk information across the organization, and reporting on risk, culture, and performance to relevant stakeholders.

Koleksi digital milik UPT Perpustakaan ITB untuk keperluan pendidikan dan penelitian



Figure 2. 1 - The COSO Enterprise Risk Management (ERM) framework

Together, these components and the principles form ideas of enterprise risk management offer a comprehensive strategy that helps businesses better to recognize, evaluate, and reduce risks. In this case, the utilization of COSO's components facilitates the systematic management of compliance risks including unauthorized access, breaches and misuse to data in SIMRS. This approach enables hospitals to assess the risk of the control environment, control activities, information/communication, and monitoring. The framework will also help in establishing a balance between operational objectives and regulatory requirements.

The identification and management of privacy risks will be assessed across leadership, policy, and operations through the implementation of the COSO ERM components in the context of Ropari hospital with identified findings to be explain in chapter 4 include:

- Governance and Culture: There is no mandatory Data Protection Officer, and hardly leadership conduct nor policy incorporate privacy obligations.
- Strategy and Objective-Setting: The hospital’s risk register excludes SIMRS vulnerabilities and privacy risks, which suggests insufficient strategic planning.
- Performance: Hospital has limited monitoring tools, consent processes, and breach detection that are not reactive because of vendor dependency.

- Review and Revision: Although focusing on hospital risks, the relevant hospital SOPs and IT protocols are outdated that have not been revised post-PDP Law enactment.
- Information and Communication: Audit logs are hardly accessed internally, and no formal communication exists regarding privacy risk.

II.1.2. ISO/IEC 27701:2019 Privacy Information Management (PIMS)

To implement and adherence the identification of privacy risk, a thorough framework is needed to guaranteeing data availability, confidentiality, and integrity. Personal Information Management System (PIMS) are designed to convert abstract data protection principles into implementable controls by integrating various technical and organizational measures that translate high-level privacy principles into actionable attempt such as “user-centric approach” to decide when with whom to share the data (Janssen et al., 2020).

Thus, information security management that provided by the International Organization for Standardization/International Electrotechnical Commission 27701:2019 (ISO PIMS) should be a compliment in terms of operational and governance-level mechanisms that directly translate privacy laws (such as GDPR or PDP Law) into technical and procedural requirements.

The implementation of ISO/IEC 27701 is not merely regulatory exercise. It also strengthens accountability and makes sure that privacy risks are identified, managed, and mitigated through a structured, risk-based approach. Moreover, it also facilitates compliance with overarching privacy laws such as the European Union General Data Protection Regulation (GDPR) and Indonesia's Personal Data Protection Law (PDP Law), thereby providing coherence between legal norms and information management practices is important (Kuner et al., 2020).

In healthcare institutions, the adoption of ISO/IEC 27701 is particularly strategic. Putting safeguards for sensitive medical information that often contain personal and health-related information, and the stakes privacy violations are relatively high. Therefore, integrating ISO PIMS will enables healthcare

Koleksi digital milik UPT Perpustakaan ITB untuk keperluan pendidikan dan penelitian

Koleksi digital milik UPT Perpustakaan ITB untuk keperluan pendidikan dan penelitian

institutions to go beyond legal minimums and for achieving both regulatory compliance and patient trust (Alsyouf et al., 2021).

The obligations to personal data subjects under ISO PIMS are aligned with the rights and duties outlined in the General Data Protection Regulation (GDPR) or Indonesia's Personal Data Protection Law (PDP Law) that shares the same concept, which in this case specifically are privacy-by-design to embed into the architecture IT System and business practices from the beginning (Cavoukian, 2009). Also aligned with patient trust that is essential for the success of digital health systems and health information exchanges, and long-term data stewardship fosters patient trust that reflects an enduring responsibility to protect personal health information across its lifecycle, ensuring both privacy and data quality over time (McGraw et al., 2009).

Below are key aspects of how the implementation of ISO/IEC 27701 will support the privacy governance:

II.1.2.1. Right to Access, Correct, and Delete Personal Data

- **Right to Access**: This right ensures transparency and allows individuals to verify the accuracy and legality of data processing activities (Di Martino et al., 2022).
- **Right to Rectification**: Ensuring data accuracy and allowing corrections of incorrect or outdated data (Häuselmann & Custers, 2024).
- **Right to Erasure**: Supporting the right to be forgotten, particularly when data is no longer necessary for its original purpose (González Fuster, 2020).
- **Right to Information**: Requiring organizations to communicate clearly about data processing purposes, retention, and data-sharing practices (Kuner et al., 2020).

Koleksi digital milik UPT Perpustakaan ITB untuk keperluan pendidikan dan penelitian

II.1.2.2. Obligation to Inform Data Subjects

- **Transparency and Information**: The GDPR mandates that data controllers provide data subjects with clear and comprehensive information about the processing of their personal data, as outlined in Articles 13 and 14. This includes informing them of any changes to the data processing activities, such as changes in the purpose of processing or the identity of the data controller (Kuner et al., 2020).
- **Notification of Changes**: When there are changes to the data processing activities, data controllers must inform data subjects promptly. This obligation ensures that data subjects are aware of how their data is being used and can exercise their rights effectively (Kuner et al., 2020).

Although PIMS provide robust framework for safeguarding information security and maintaining patient confidentiality, real-world implementation often lags due to organizational and technical challenges (Manongga et al., 2024). The effectiveness of PIMS in addressing systemic issues in data ecosystems is still under scrutiny, as many of these issues persist despite the adoption of PIMS. Additionally, the success of PIMS depends on the willingness of organizations to adopt these systems and the robustness of the legal and technical frameworks supporting them (Janssen et al., 2020).

II.1.3. Indonesian Personal Data Protection Law No.27/2022 (PDP Law)

With the enactment of Indonesia's own data protection regulation, it also marks the nation's first regulation that comprehensively governing personal data in 2022. The regulation was established based on privacy concept of European Union's General Data Protection Regulation (GDPR) in 2018, therefore, PDP Law emphasize in the rights of the personal data that refers to any data about an individual who is identified or can be identified either directly or indirectly. data subject in this case an individual who holds personal data. The individual data is referred to as the data subject, and in the context of healthcare, this is typically the patient. Although healthcare providers are acknowledged to complied with

Koleksi digital milik UPT Perpustakaan ITB untuk keperluan pendidikan dan penelitian

the patient privacy based on the Indonesia's Health Law (UU Kesehatan), the PDP Law provides a clearer, more comprehensive framework for data governance. Unlike the general clauses in Health Law that ensure confidentiality in clinical context it expands the understanding of personal data rights and institutional responsibilities, requiring healthcare providers functioning as data controllers for data process to meet explicit obligations for respecting data subject rights, ensuring transparency, and provide the security of sensitive health information across the data lifecycle.

PDP Law offers key principles and provisions include:

- **Rights of Data Subjects**: These include the right to access, correct, and delete personal data, as well as the right to object to data processing, withdraw consent, and seek legal remedies in the event of misuse.
- **Obligations of Data Controllers and Processors**: Organizations must establish lawful grounds for data processing, ensure purpose limitation, maintain data minimization, and guarantee data accuracy and security.
- **Data Breach Notification** (Article 21): Entities must report data breaches to both affected parties and regulatory authorities within 3x24 hours.
- **Privacy by Design and Default** (Article 28): Data protection measures must be integrated at the design phase of any system involving personal data, with default settings ensuring maximum protection.
- **Governance Requirements** (Articles 46–49): Organizations are required to appoint a Data Protection Officer (DPO) under certain conditions, conduct risk assessments, and maintain audit trails.
- **Regulatory Oversight** (Article 58): Establishes the supervisory authority.

Koleksi digital milik UPT Perpustakaan ITB untuk keperluan pendidikan dan penelitian

These provisions form a legal framework that aligns closely with the principles outlined in ISO/IEC 27701:2019. For instance, the ISO standard's requirements on consent, data subject rights, risk assessments, and breach response directly reinforce PDP Law compliance, supporting practical integration in healthcare settings where structured privacy controls are increasingly critical.

However, both internal and external failures in adhering to PDP Law provisions can result in significant regulatory, operational, and reputational consequences that identified as compliance risks include:

- Delay in breach notification (Article 21 paragraph 3): Failure to notify the breach of affected parties within 3x24 hours, can result in legal penalties and loss of public trust.
- Unauthorized internal access (Article 46): Inadequate internal controls may lead to staff accessing data beyond their authorization scope.
- Absence of documented consent (Article 20): Failure to record and trace consent undermines legal basis for data processing.
- Lack of audit trail and monitoring (Article 49 paragraph 3): Without audit logs, breach detection and accountability are severely impaired.
- Insufficient technical safeguards (Article 39): Inadequate encryption, authentication, and monitoring mechanisms expose systems to external threats.

Recognizing these failures emphasizes the importance of adopting an integrated privacy risk strategy. PDP Law provides the regulatory framework; ISO/IEC 27701 translates obligations into operational controls; and COSO ERM embeds privacy into the broader strategic governance of hospital systems.

II.1.4. Governance Gaps

Although COSO ERM provides a comprehensive framework for enterprise risk governance, and ISO/IEC 27701 outlines detailed privacy control standards, healthcare institutions often fall short in bridging these frameworks to operational practice.

Koleksi digital milik UPT Perpustakaan ITB untuk keperluan pendidikan dan penelitian

Governance gaps in digital privacy typically involve:

1. People (Leadership, Roles, and Awareness)

   Many hospitals lack a centralized governance structure for data privacy. This includes the absence of a designated Data Protection Officer (DPO), limited executive-level ownership of privacy risk, and inadequate cross-departmental coordination. Moreover, awareness of the PDP Law's implications remains low among medical, IT, and administrative personnel.

2. Systems (SIMRS Architecture and Interoperability)

   SIMRS modules—ranging from patient registration and billing to medical records and diagnostics—often operate in silos, lacking integrated privacy-by-design controls. Most systems do not support interoperability standards, real-time logging, or granular user access tracking, making it difficult to monitor and secure data flows. This gap undermines COSO's Monitoring & Reporting and ISO/IEC 27701's technical and organizational measures for secure data processing.

3. Tools (Access Control, Authentication, and IT Logs)

   Technical tools to enforce privacy policies—such as **role-based access control (RBAC)**, **multi-factor authentication (MFA)**, and **system-wide audit trails**—are often missing or applied unevenly. These deficiencies weaken the institution's ability to **detect unauthorized access**, **reconstruct breach events**, or **demonstrate compliance**. This contradicts the control activity principles of **COSO ERM** and the enforcement safeguards under **ISO/IEC 27701 Clause 7.5**.

4. Storage (Data Lifecycle and Classification)

   Patient data in SIMRS is frequently stored without clear data classification, retention policies, or backup protocols. Sensitive health data—such as lab results, clinical notes, and patient identifiers—are sometimes stored in shared drives or unsecured legacy databases, making

them vulnerable to breaches. This violates key mandates of PDP Law Articles 35–39 and ISO's requirement for data minimization and retention.

5. Processes (Risk Management, DPIA, and Breach Response)
   Hospitals rarely conduct Data Protection Impact Assessments (DPIA) when launching new digital initiatives or third-party integrations. Similarly, incident response procedures for breaches—such as reporting timelines and containment protocols—are poorly defined or absent. These weaknesses reflect a gap in COSO's Risk Assessment component and PDP Law Article 34, which mandates risk-based mitigation.

These issues are addressing where privacy governance tends to be fragmented, reactive, and compliance driven rather than proactive. Furthermore, while PDP Law provides important legal obligations such as consent, purpose limitation, and breach notification, it does not offer hospitals a clear operational roadmap for implementation data privacy governance.

II.2. Conceptual Framework

A conceptual framework is an interconnected system of underlying assumptions, expectations, and beliefs. It represents a preliminary theory that directs research (Tamene, 2016). In this study, conceptual framework serves as the fundamental and pivotal component of the research design, offering guidance both to understanding the research's direction and for the reader to comprehending objectives, methods and outcomes. In this case it is to address privacy risks in improving hospital information systems (SIMRS) towards privacy governance.

This study adopts an integrated conceptual framework grounded in three synergistic pillars:

1. COSO ERM (Enterprise Risk Management) 2017 offers a governance-oriented structure for embedding privacy into the organization's risk landscape.

Koleksi digital milik UPT Perpustakaan ITB untuk keperluan pendidikan dan penelitian

2. ISO 27701 (Privacy Information Management) translates privacy obligations into operational and technical controls that can complement frameworks to integrate privacy risks within the hospital's data workflows.
3. Indonesia's Personal Data Protection (PDP) Law No. 27/2022 as the legal foundation, to establish the rights of data subjects, identify breach reporting mandates on data failures and compliance baseline to emphasize the current patient's data confidentiality and hospital obligations based on Health Law in Indonesia.

Together, these frameworks align legal mandates, organizational policies, and technical safeguards, enabling hospitals to institutionalize privacy governance that has been supported by previous that evaluate the direct application of healthcare privacy context who demonstrated the utility of how COSO ERM improving risk governance and compliance in clinical and non-clinical hospital processes to supports clinical and administrative risk control integration (Etges and Grenon 2018).

Leveraging COSO ERM as the main framework aligning with ISO PIMS and PDP Law can create a conceptual framework that will design a suggestion for data privacy governance and future improvement in managing privacy risk with approaches such as:

II.2.1. Governance & Strategic Alignment

- COSO's "Governance & Culture" and "Strategy & Objective-Setting" components reinforce the leadership commitment and alignment of privacy are within the organizational structure.
- ISO 27701 Clause 5.2.2 and PDP Law Article 48 support the mandatory appointment of a DPO or dedicated person to create structured accountability, addressing governance fragmentation.

II.2.2. Risk Assessment & Prioritization

COSO's risk assessment functions combined with ISO 27701 Clause 6.2 and PDP Law Article 28 (Privacy by Design) provide mechanisms to detect,

Koleksi digital milik UPT Perpustakaan ITB untuk keperluan pendidikan dan penelitian

Koleksi digital milik UPT Perpustakaan ITB untuk keperluan pendidikan dan penelitian

prioritize, and proactively mitigate privacy risks to overcome institutional inattention to non-clinical risks and privacy exclusions in risk registers.

II.2.3. Control Activities

COSO recommends *Control Activities* such as access restrictions and audit trails to mitigate risks with several requirements such as data minimization, breach notification and consent requirements in processing personal data.

II.2.4. Monitoring & Reporting

COSO ERM requires continuous monitoring and internal audits to evaluate risk responses and promote iterative feedback loops, if necessary, align with ISO PIMS to ensure compliance tracking.

This integrated model serves as both a diagnostic tool and a strategic blueprint. It supports Ropari Hospital in transitioning from fragmented compliance to embedded risk governance in SIMRS.

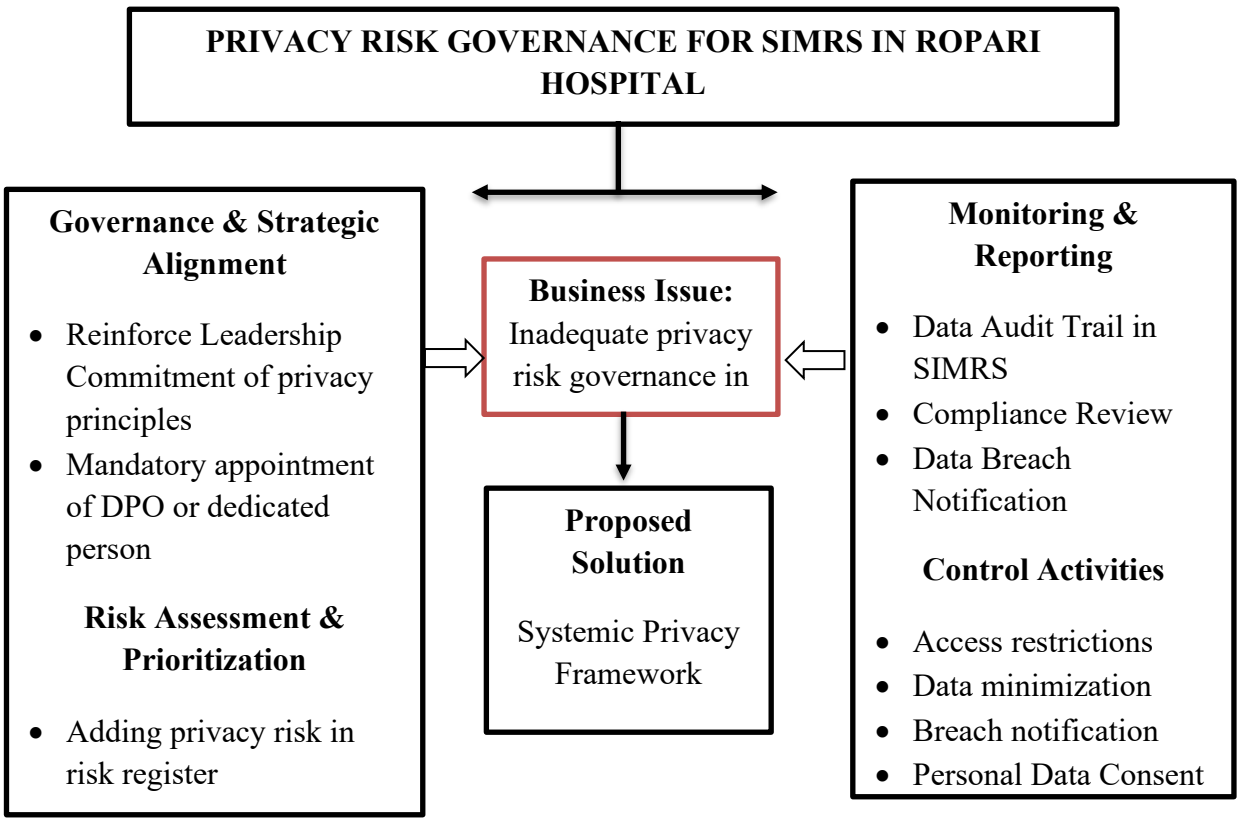


Figure 2. 2 - Conceptual Framework

Koleksi digital milik UPT Perpustakaan ITB untuk keperluan pendidikan dan penelitian

II.3. Applied Studies on Governance of Digital Health Information

To validate the conceptual framework proposed in this study, recent applied studies from various health systems offer empirical evidence that supports the integration of organizational governance (COSO ERM), technical privacy controls (ISO/IEC 27701), and regulatory compliance (PDP Law). These studies provide insights into how hospitals and health systems have addressed data protection and governance challenges many of which integrates those observed in Indonesian contexts.

Study of governance and strategic alignment by Ghaffari Heshajin et al. (2024) consist of six foundational dimensions of health information governance: goals, principles, components, roles, responsibilities, and processes are consistent with COSO ERM's focus on leadership, structure, and organizational accountability. The findings of this study are to emphasize the need of formalized internal roles and risk ownership for effective privacy risk in health systems.

Other study that analyzing HIPAA compliant mandatory requirements revealed that compliance alone does not guarantee data protection. The study of Subramanian et al. (2024) emphasizes the importance of risk assessment and prioritization. Particularly, the study proposes to embed risk literacy into organizational routines that focusing on internal controls, training, and procedural safeguards that resonate with the risk identification and monitoring that implemented in COSO ERM.

Further validation of this study's conceptual framework particularly the legal and compliance dimension drawn from Indonesia's PDP Law No. 27/2022 is provided by recent applied studies examining privacy risk and governance alignment that conducted by Prayuti (2024) focusing on normative-legal as the implications of the PDP Law in managing consumer health data consist of regulatory mechanisms (e.g., transparency, consent, purpose limitation) and actual implementation remains weak across Indonesia's healthcare systems.

And study of Prabowo et al. (2025), employing a stakeholder-driven quantitative study, developed a localized Data Protection Impact Assessment (DPIA) framework based on GDPR principles which directly support the risk assessment

and control activities components in the COSO ERM domain of the conceptual model.

These previous summarize applied studies collectively illustrate the fragmented privacy risk governance in health systems which are classified by the integration of the proposed conceptual framework in this study. This study will fill the gap of the privacy governance framework provided in this table.

No	Title	Author(s)	Yr	Gov Align (COSO)	Risk Assmt (COSO)	Ctrl Act (ISO 27701)	Monitor (PDP/ISO)	Legal Comp (PDP Law)
1	A framework for health information governance: A scoping review	Ghaffari Heshajin et al.	2024	✓	✗	✗	✓	✗
2	Patient health record protection beyond HIPAA: Mixed methods study	Subramanian et al.	2024	✓	✓	✓	✗	✗
3	EMR adoption in Dubai healthcare facilities	Abdulrahman et al.	2024	✗	✗	✓	✓	✓
4	Implications of PDP Law in consumer health data management	Prayuti	2024	✓	✗	✓	✗	✓
5	DPIA framework for Indonesia based on GDPR principles	Prabowo et al.	2025	✗	✓	✓	✓	✓

Koleksi digital milik UPT Perpustakaan ITB untuk keperluan pendidikan dan penelitian